

ÉCOLE HECM AFRIQUE — BOHICON

Filière : SSI 2 | Semestre 4 | Année 2025-2026

Enseignant : M. YESSOUFOU | Durée : 2 heures

AUDIT DE SÉCURITÉ INFORMATIQUE

Étude de cas — Entreprise ALIBORI TECH

Réalisé par :

GBOKPANNON Onésime

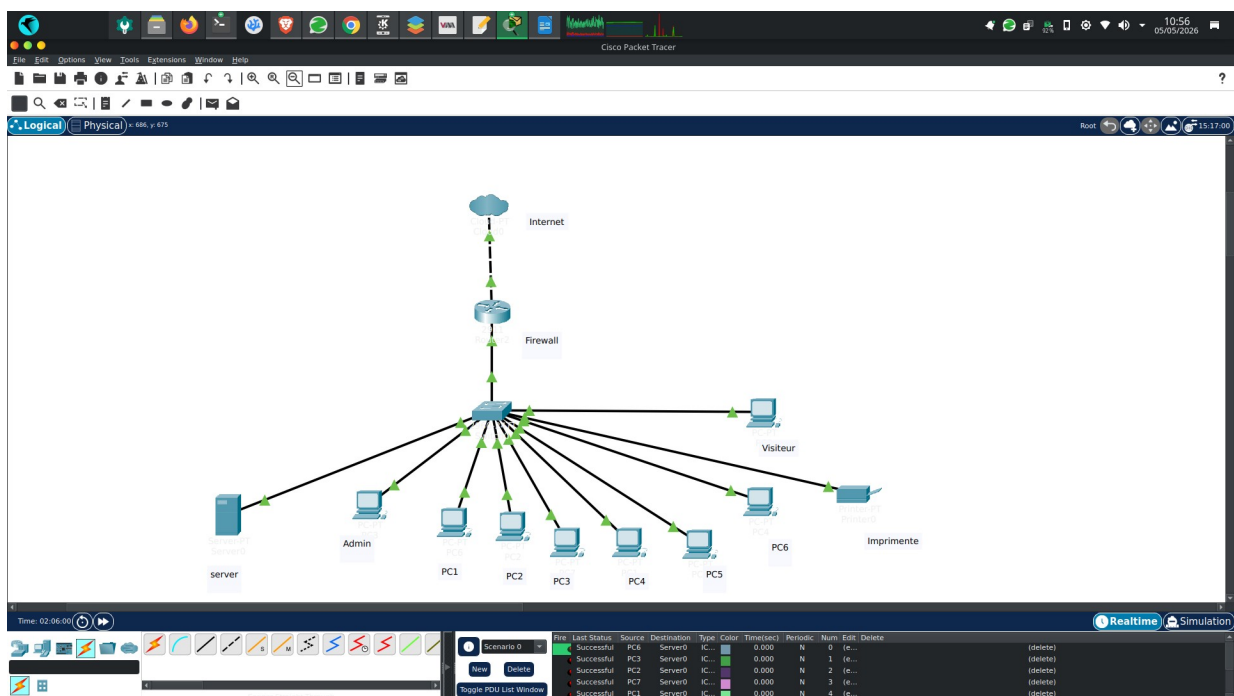
Étudiant en SSI2 — HECM Afrique Bohicon

INTRODUCTION

L'entreprise ALIBORI TECH est une PME de 35 employés dont le système informatique repose sur un réseau local connecté à Internet via un routeur et un pare-feu. Un serveur central fournit plusieurs services réseau aux postes du personnel.

Le responsable informatique a signalé plusieurs anomalies : accès lent à certaines ressources, comptes utilisateurs mal gérés, absence de sauvegarde et exposition de services inutiles. Le présent document constitue le rapport d'audit de sécurité réalisé dans le cadre de l'étude de cas.

Objectif de l'audit : identifier les failles de sécurité, évaluer les risques et proposer des mesures correctives réalistes, à partir d'une simulation de l'infrastructure sous Cisco Packet Tracer.



PARTIE 1 — IDENTIFICATION DES ACTIFS

1. Relevé des actifs du système

L'infrastructure informatique d'ALIBORI TECH comprend les actifs suivants :

- **Équipements réseau** : 1 routeur principal, 1 pare-feu, 1 switch central de niveau 2.
- **Serveur central** : héberge les services DHCP, DNS, HTTP/HTTPS, FTP, SMTP/POP3 et le partage de fichiers.
- **Postes de travail** : 6 postes clients (PC1 à PC6), 1 poste administrateur, 1 poste visiteur.
- **Périphériques** : 1 imprimante réseau.
- **Données** : fichiers métier, identifiants utilisateurs, messagerie interne, configuration réseau.

2. Classification des actifs

Actif	Catégorie	Justification
Serveur central	Critique	Héberge tous les services essentiels
Pare-feu	Critique	Première ligne de défense contre les attaques
Routeur principal	Critique	Seul point de connexion à Internet
Données métier	Critique	Informations vitales de l'entreprise
Comptes utilisateurs	Critique	Donnent accès à toutes les ressources
Poste administrateur	Sensible	Accès privilégié à tout le système
Messagerie interne	Sensible	Contient des échanges confidentiels
Fichiers partagés	Sensible	Accessibles sans restriction suffisante
Switch central	Secondaire	Ne stocke pas de données
Postes clients PC1-PC6	Secondaire	Outils de travail des employés
Imprimante réseau	Secondaire	Service utile mais non critique

3. Données à protéger en priorité

- **Identifiants et mots de passe** des comptes utilisateurs et administrateur.
- **Fichiers techniques** déposés via FTP.
- **Données financières** de l'entreprise stockées sur le serveur.

- **Messagerie interne** contenant des échanges confidentiels.
- **Configuration du pare-feu et du routeur** si volée, l'attaquant connaît toute l'architecture réseau.
- **Données personnelles** des 35 employés, protégées par la réglementation en vigueur.

4. Services essentiels au fonctionnement

Service	Rôle	Statut
DHCP	Attribution automatique des adresses IP	Essentiel
DNS	Résolution des noms de domaine internes	Essentiel
HTTPS	Accès sécurisé au portail intranet	Essentiel
SMTP/POP3	Messagerie interne entre employés	Essentiel
HTTP	Portail non sécurisé, à remplacer par HTTPS	A désactiver
FTP	Accessible à tous sans restriction	A limiter
Telnet	Transmet les données en clair	A désactiver

PARTIE 2 — ANALYSE DE LA CONFIGURATION

1. Services nécessaires et services à risque

L'analyse des services actifs sur le serveur révèle plusieurs problèmes de configuration.

- **DHCP, DNS, HTTPS, SMTP/POP3** : services nécessaires au fonctionnement quotidien, à conserver.
- **HTTP** : service non chiffré, à désactiver. Tout le trafic web doit passer uniquement par HTTPS.
- **FTP** : service à risque car accessible sans restriction d'adresse IP. N'importe quel poste peut accéder aux fichiers.
- **Telnet** : service dangereux à désactiver immédiatement. Il transmet les mots de passe en clair sur le réseau.
- **Partage de fichiers** : à restreindre selon les profils utilisateurs — tout le monde ne doit pas accéder à tous les dossiers.

2. Comptes utilisateurs mal protégés

- **Mot de passe administrateur faible** : facile à deviner, sans politique de complexité définie.
- **Aucun renouvellement périodique** : les mots de passe ne sont jamais changés.
- **Aucune différenciation des droits** : les postes PC1 à PC6 ont les mêmes accès que l'administrateur.
- **Absence d'authentification à deux facteurs** : un seul mot de passe suffit pour compromettre un compte.

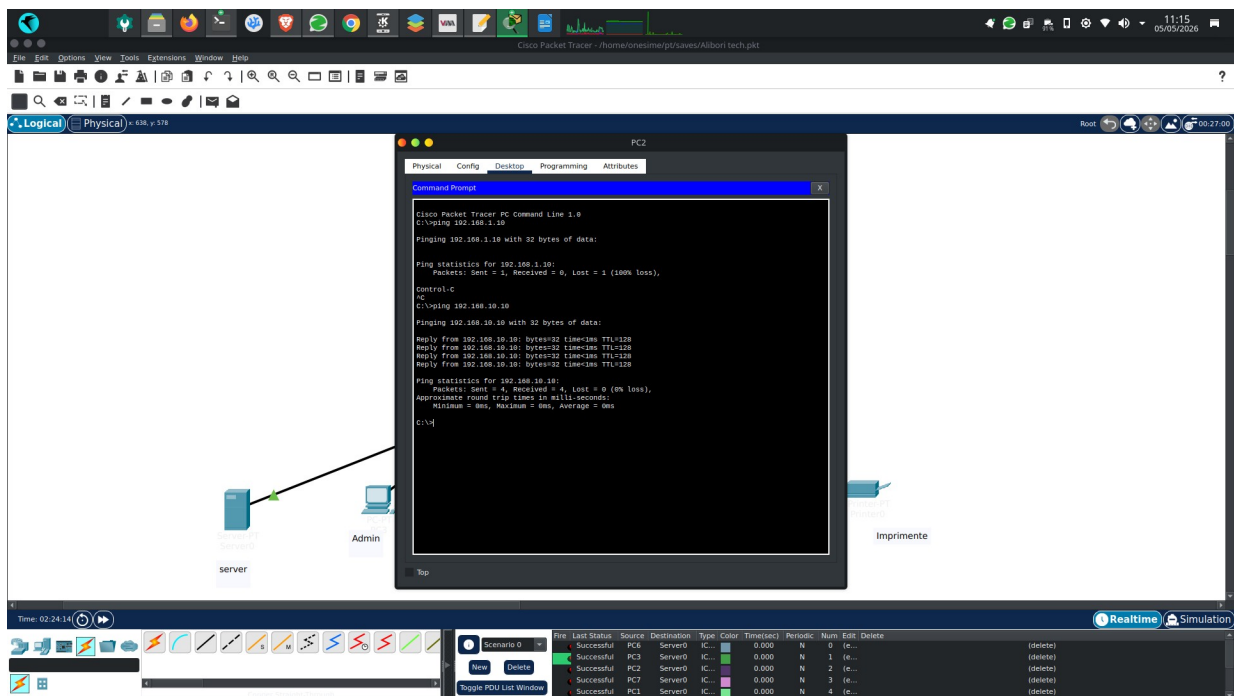
3. Défauts de segmentation réseau

- **Réseau unique 192.168.10.0/24** : tous les équipements sont sur le même réseau sans aucune séparation logique.
- **Poste visiteur non isolé** : un visiteur peut accéder aux ressources internes de l'entreprise.
- **Serveur non isolé** : en cas de compromission d'un PC, le serveur est directement accessible.
- **Absence de VLANs** : aucune segmentation entre les utilisateurs, l'administration et le serveur.
- **Imprimante accessible sans restriction** : tout le réseau peut envoyer des documents à l'imprimante.

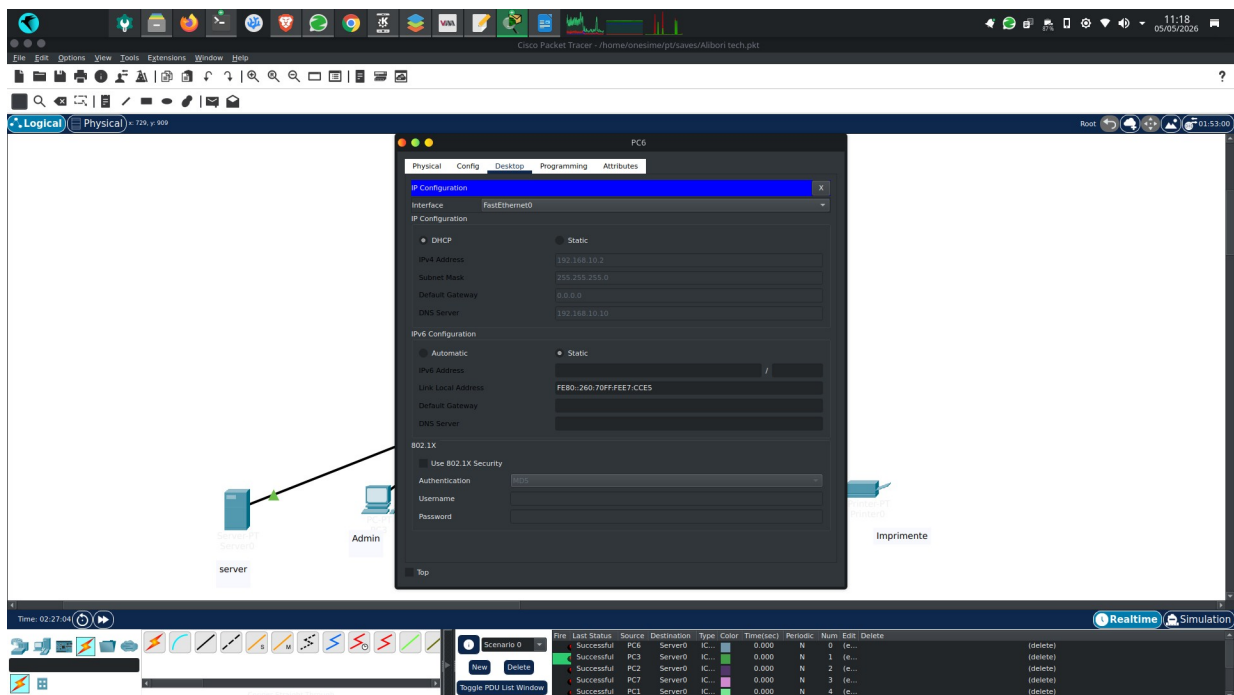
4. Manque de supervision et de mise à jour

- **Journaux système non consultés** : aucune détection d'intrusion possible, les incidents passent inaperçus.
- **Aucune sauvegarde automatique** : perte totale des données en cas de panne ou d'attaque.
- **Pare-feu mal configuré** : autorise du trafic entrant inutile depuis Internet.
- **Absence de politique de mise à jour** : les équipements et logiciels ne sont pas maintenus à jour.
- **Aucun outil de surveillance réseau** : les anomalies de trafic ne sont pas détectées en temps réel.

Tests de connectivité entre PC et serveur



Succes du ping



Succes d'attribution des adresses IP par le serveur DHCP

PARTIE 3 — ANALYSE DES RISQUES

Pour chaque anomalie identifiée, nous analysons la menace possible et son impact sur les trois piliers de la sécurité : Confidentialité (C), Intégrité (I) et Disponibilité (D).

1. Mot de passe administrateur faible

- **Menace** : intrusion par force brute ou par simple devinette du mot de passe.
- **Confidentialité** : critique — l'attaquant accède à toutes les données de l'entreprise.
- **Intégrité** : critique — il peut modifier ou supprimer des fichiers sans laisser de trace.
- **Disponibilité** : critique — il peut bloquer l'accès au système entier.
- **Justification** : un mot de passe faible est la première faille exploitée. Aucune compétence technique avancée n'est nécessaire.

2. Service FTP accessible à tous

- **Menace** : vol, modification ou suppression de fichiers sensibles par n'importe quel employé ou intrus.
- **Confidentialité** : critique — les fichiers confidentiels sont accessibles sans restriction.
- **Intégrité** : critique — les fichiers peuvent être modifiés ou supprimés sans trace.
- **Disponibilité** : moyenne — les fichiers peuvent être effacés, rendant le service indisponible.
- **Justification** : le FTP sans restriction est une porte ouverte sur les données internes.

3. Ports HTTP et Telnet ouverts

- **Menace** : écoute du réseau permettant de capturer les mots de passe transmis en clair via Telnet.
- **Confidentialité** : critique — les identifiants circulent sans chiffrement.
- **Intégrité** : moyenne — les commandes peuvent être interceptées et modifiées.
- **Disponibilité** : faible — impact indirect via la compromission des comptes.
- **Justification** : Telnet ne chiffre rien. Une simple écoute réseau suffit pour capturer un mot de passe.

4. Aucune sauvegarde automatique

- **Menace** : perte définitive de toutes les données en cas de panne, ransomware ou erreur humaine.
- **Confidentialité** : faible impact direct.
- **Intégrité** : critique — les données corrompues ne peuvent pas être restaurées.

- **Disponibilité** : critique — l'entreprise ne peut pas reprendre son activité après un incident.
- **Justification** : sans sauvegarde, la moindre attaque peut paralyser l'entreprise définitivement.

5. Pare-feu mal configuré

- **Menace** : accès direct depuis Internet aux services internes de l'entreprise.
- **Confidentialité** : critique — les données internes sont exposées à Internet.
- **Intégrité** : critique — un attaquant externe peut modifier les données.
- **Disponibilité** : critique — une attaque par déni de service peut bloquer tout le réseau.
- **Justification** : un pare-feu mal configuré ne protège pas. C'est comme une porte blindée laissée ouverte.

6. Journaux système non consultés

- **Menace** : une intrusion peut passer inaperçue pendant des semaines.
- **Confidentialité** : critique — un attaquant vole des données sans être détecté.
- **Intégrité** : moyenne — des modifications malveillantes passent inaperçues.
- **Disponibilité** : moyenne — les pannes ne sont pas anticipées.
- **Justification** : sans surveillance des journaux, l'entreprise est aveugle face aux attaques.

PARTIE 4 — RECOMMANDATIONS DE SÉCURITÉ

Sept mesures correctives sont proposées pour remédier aux failles identifiées.

1. Désactiver les services inutiles

Le service Telnet transmet les mots de passe en clair sur le réseau. N'importe qui qui surveille le trafic peut les intercepter.

- **Action** : désactiver Telnet et le remplacer par SSH qui chiffre toutes les communications.
- **Commande Cisco** : `line vty 0 4 / transport input ssh / login local`

2. Limiter l'accès au service FTP par adresse IP

Le FTP est actuellement accessible depuis tous les postes du réseau sans distinction.

- **Action** : créer une ACL autorisant le FTP uniquement depuis le poste administrateur (192.168.10.20).
- **Effet** : les employés standard ne peuvent plus accéder directement aux fichiers via FTP.

3. Renforcer les mots de passe

Le mot de passe administrateur est faible et facilement devinable.

- **Action** : imposer des mots de passe d'au moins 12 caractères combinant majuscules, minuscules, chiffres et symboles.
- **Politique** : renouvellement obligatoire tous les 90 jours, historique des 5 derniers mots de passe interdit.

4. Mettre en place des sauvegardes automatiques

L'absence de sauvegarde expose l'entreprise à une perte totale et définitive de ses données.

- **Action** : programmer une sauvegarde automatique quotidienne vers un disque externe ou un serveur distant.
- **Règle 3-2-1** : 3 copies des données, sur 2 supports différents, dont 1 hors site.

5. Reconfigurer le pare-feu

Le pare-feu autorise actuellement du trafic entrant inutile depuis Internet, exposant le réseau interne.

- **Action** : appliquer une politique de refus par défaut — bloquer tout le trafic entrant et n'autoriser que les connexions explicitement nécessaires.

- **Principe** : tout ce qui n'est pas explicitement autorisé est interdit.

6. Activer et consulter les journaux système

Sans journaux, l'entreprise est aveugle face aux intrusions et incidents.

- **Action** : activer la journalisation sur le serveur, le pare-feu et le routeur.
- **Fréquence** : consultation quotidienne des journaux ou mise en place d'alertes automatiques en cas d'anomalie.

7. Isoler la zone visiteurs et le serveur

Le poste visiteur partage le même réseau que les postes internes, ce qui représente un risque majeur.

- **Action** : créer un VLAN dédié aux visiteurs sans accès au réseau interne.
- **Action complémentaire** : isoler le serveur dans un VLAN serveur dédié pour limiter l'exposition en cas de compromission d'un PC.

Conclusion : L'audit de sécurité d'ALIBORI TECH révèle six failles majeures touchant les trois piliers de la sécurité informatique. La mise en oeuvre des sept recommandations proposées permettrait de réduire significativement la surface d'attaque de l'entreprise et de protéger ses actifs critiques contre les menaces internes et externes.